John the Ripper

Các kỹ thuật dò mật khẩu ngoại tuyến

Hai kịch bản trên dữ liệu tổng hợp

Nhóm 3 thành viên TV1 • TV2 • TV3

29/10/2026

Mục tiêu nghiên cứu

RQ1 Chiến lược nào phù hợp với từng nhóm mật khẩu?

RQ2 Giả định đúng và sai về cấu trúc ảnh hưởng ra sao?

RQ3 Hàm băm và cost thay đổi chi phí thử thế nào?

RQ4 Điều kiện nào cho phép so sánh hai công cụ?

Luồng xử lý ngoại tuyến

01 Nạp hash, metadata và chọn định dạng

02 Sinh ứng viên theo chiến lược đã chọn

03 Tính giá trị với salt và cost rồi so khớp

04 Ghi kết quả vào pot, lưu trạng thái session

Các kỹ thuật trong thực nghiệm

Kỹ thuật	Thông tin đầu vào	Ứng dụng trong lab
Wordlist	Danh sách từ	Từ gốc G1
Rules	Từ gốc và phép biến đổi	Biến thể G2
Mask	Cấu trúc theo vị trí	Hai chữ và bốn số G3
Incremental	Charset, chiều dài, thống kê	LowerNum dài 1–6
Single	Metadata tài khoản	Tám tài khoản giả

Mỗi kỹ thuật chỉ có thể tìm đáp án nằm trong không gian đã thử

Môi trường và dữ liệu

Thuộc tính	Cấu hình
John	1.9.0-jumbo-1 Windows x64, AVX2, OpenMP 4 luồng
Máy	Intel Core i7-7700HQ, Windows 10
Dữ liệu	100 mật khẩu, 5 nhóm, 20 mật khẩu mỗi nhóm
Ứng viên	1.000 từ gốc, 4.000 chuỗi sau rules
Phương pháp	Ba lượt độc lập, tối đa 60 giây/lượt

Pot riêng từng lượt • Kiểm tra checksum • Đối chiếu ground truth

Kịch bản 1 và giả thuyết

A1 Wordlist: kiểm tra từ có sẵn trong danh sách

A2 Rules: kiểm tra biến thể viết hoa và hậu tố

A3 Mask đúng: $26^2 \times 10^4 = 6.760.000$ chuỗi

A4 Incremental: LowerNum dài 1–6, giới hạn 60 giây

Tiểu thử: mask sai và single với metadata giả lập

Kết quả theo chiến lược



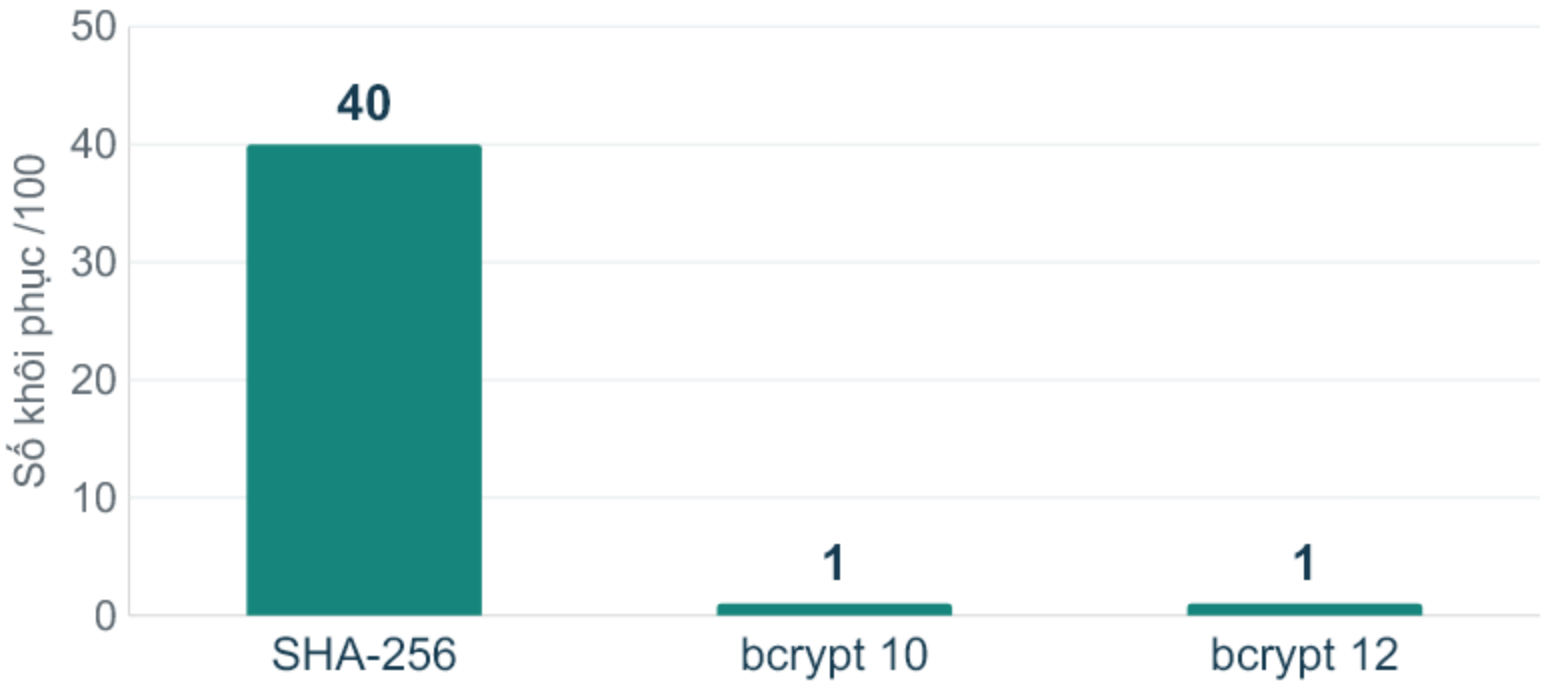
20/100 từ wordlist

40/100 khi thêm rules

20/20 mật khẩu G3 với mask đúng

G4/G5 chưa tìm được trong điều kiện đã thử

Kịch bản 2 với cùng 4.000 ứng viên

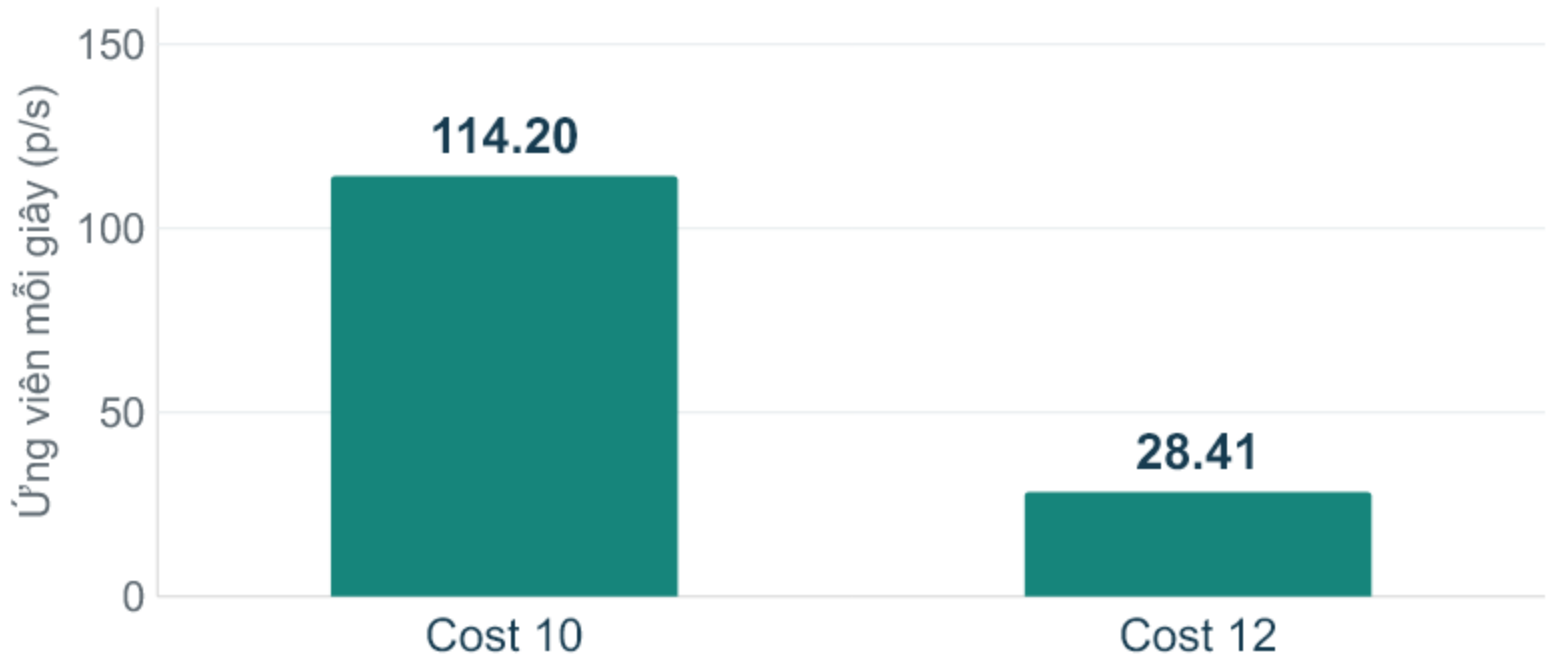


Giữ nguyên dữ liệu và thứ tự ứng viên

Bcrypt cần nhiều phép xác minh theo salt

Giới hạn thời gian có thể dừng trước đáp án

Cost bcrypt trong đối chứng một hash



4.02 lần

Chênh lệch tốc độ median giữa hai mức cost

Log báo 1.024 và 4.096 vòng lặp tương ứng cost 10 và 12

Đối chiếu John và Hashcat

Cấu hình	Kết quả trên 4.000 ứng viên
John CPU, 4 luồng	40/100; wall median 0.37 giây
Hashcat CPU	Không có CPU OpenCL backend
Hashcat GPU Intel	40/100; wall median 2.14 giây

Backend khác nhau và tập thử nhỏ giới hạn kết luận về tốc độ

Kết luận và giới hạn

Chiến lược hiệu quả khi tập ứng viên phù hợp với mật khẩu

Cost cao hơn làm tăng chi phí thử trong cấu hình được đo

Phòng vệ cần mật khẩu khó đoán và cơ chế lưu phù hợp

Giới hạn: dữ liệu tổng hợp, 60 giây, một máy Windows

Tài liệu và dữ liệu kiểm chứng

Openwall: tài liệu John, modes, rules, mask và options

Hashcat: tài liệu, thiết bị và định dạng hash

OWASP Password Storage • NIST SP 800-63B-4 • RFC 9106

Gói kèm: dữ liệu, checksum, lệnh, log và kết quả từng lượt